

Exercise 02 – Transport Layer Security (TLS)

1 Goals:

1. Understand the details of TLS
2. Identify the options that can be more secure in different sites providing TLS support (not all of them provide the same level of security)

2 Requirements:

1. Have OpenSSL installed on the system (in MacOS machines it is installed), and or
2. Use a Linux machine with OpenSSL

3 Useful information

The OpenSSL is the ‘facto’ implementation of encryption algorithms in diverse operating systems, including MacOS, Linux, BSD and others.

It contains several functionalities that allow it to encrypt files, test TLS connections among others.

Some useful links are:

- Docs OpenSSL commands <https://docs.openssl.org/3.0/man1/> ,
- [openssl s_client](#) to establish a connection to a TLS capable server
- [openssl s_time](#) to check timing performance
- A cheatsheet of OpenSSL can be found [here](#).

4 Steps:

4.1 General phases in the TLS connection

Choose a server with HTTPS support and check what is by the version of TLS that is used in the connection.

Use the `openssl s_client` command, with some options like

```
openssl s_client -connect instagram.com:443 -msg -trace
```

Question 1. What is the version of TLS that was established?

4.2 Force the use of another version

Use `openssl` forcing a specific version and check if the server supports an older version like TLS 1.1.

```
openssl s_client -connect instagram.com:443 -tls1_1 -msg -trace
```

Question 2. Is the connection accepted ?

4.3 Identify the version of ciphers announced by your client

When establishing the handshake your client sends a list of cipher suites that are supported.

```
openssl s_client -connect instagram.com:443 -msg -trace -debug
```

Question 3. Identify the cipher suites that are supported by the client.

Question 4. Which one is used by the server to establish the session?

Question 5. Considering the answers in the previous questions, does the server chooses the cipher that is more robust/secure¹ (e.g., with a higher key)?

¹ Many of the algorithms have not yet been spoken in the theoretical classes. Consider searching the Internet for information regarding the algorithms to answer to this question.

4.4 Timing performance

If the server supports different versions of TLS, consider in assessing its performance in terms of timing. Consider the performance regarding new sessions and reusing the sessions IDs.

Consider in doing this exercise for at least two websites. Suggestions include linkedin.com, dei.uc.pt and Instagram.com

```
openssl s_time -connect instagram.com:443 -tls1_3
```

Question 6. Which one provides more performance in terms of the number of connections and what is the maximum number of connections per user in a second.

Note: the obtained numbers might vary in different runs, consider in doing more than one run to have more confidence in the values.

4.5 Information in the certificates

Consider inspecting the certificates of the servers (chosen in the previous question). These certificates are used to authenticate the server and establish the connection.

```
openssl s_client -connect instagram.com:443 -trace
```

Question 7. Check the Subject Public Key Info field for the correct Subject (name of the server) and identify the Public Key Algorithm and the key size².

Report:

Your report should be complete and provide evidence to justify the answers in the previous questions.

The **blue team** member should execute the commands suggested in the previous exercise.

The **red team** member should sniff the tests performed with openssl client in their own machine (for instance using wireshark or other) and identify the versions of TLS being negotiated.

All the findings must be on the report.

² The public key algorithms and the structure of certificates will be detailed in future classes.